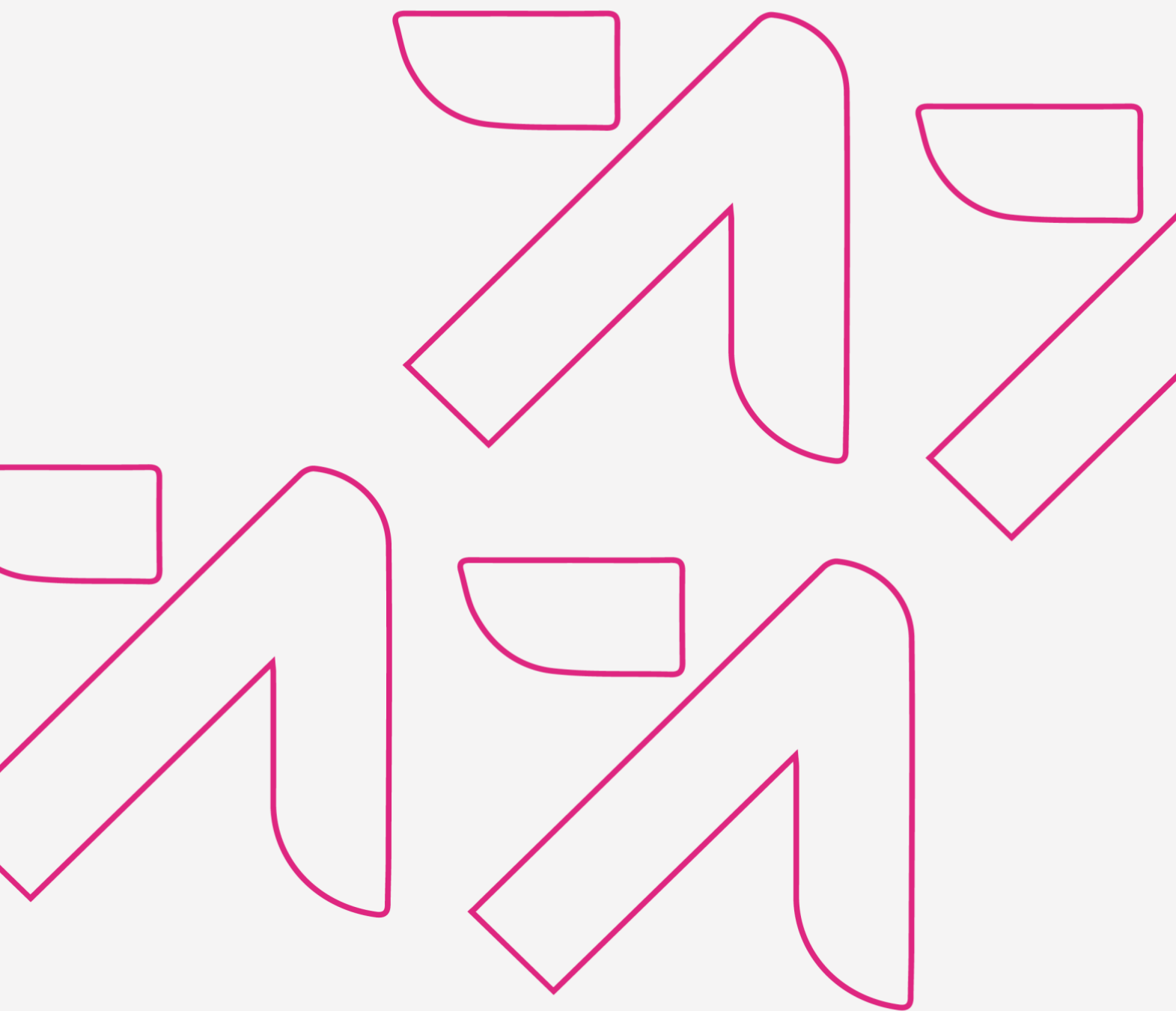




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 2. Planificación de la prevención y concienciación en ciberseguridad

Encaje en el curso 2026/2027: tema 2 del temario oficial, dentro del RA1 (planes de prevención y concienciación).

1. Por qué empezar por las personas

La mayoría de los incidentes tienen un componente humano: alguien que hace clic, que reutiliza una contraseña, que se fía de una llamada o que configura algo mal. No es un problema de torpeza, sino de diseño: los ataques están pensados para parecer trabajo normal.

Por eso la concienciación no consiste en «dar una charla al año», sino en un plan con objetivos, destinatarios, contenidos y medición, igual que cualquier otro control de seguridad.

2. El plan de concienciación

2.1. Fases

1. **Diagnóstico:** de dónde partimos. Encuestas, resultados de una simulación de phishing inicial, incidentes del último año.
2. **Objetivos:** concretos y medibles. «Subir la tasa de reporte del 5 % al 30 % en seis meses» es un objetivo; «concienciar a la plantilla» no lo es.
3. **Públicos:** no todos necesitan lo mismo. Dirección, administración, recursos humanos, atención al cliente y personal técnico tienen riesgos distintos.
4. **Contenidos y formatos:** píldoras cortas, simulaciones, carteles, sesiones prácticas, casos reales del sector.
5. **Calendario:** poco y a menudo funciona mejor que mucho de golpe.
6. **Medición y revisión:** qué ha cambiado y qué se ajusta para el siguiente ciclo.

2.2. Qué debe saber hacer cualquier empleado

- Reconocer un mensaje sospechoso y saber a quién y cómo avisar.
- Usar un gestor de contraseñas y el segundo factor.
- Bloquear el equipo y proteger los dispositivos fuera de la oficina.
- Verificar por otro canal cualquier petición inusual de dinero o de datos.
- Avisar de inmediato si cree que ha cometido un error.

3. Cultura de seguridad

3.1. Integrarla en el día a día

- El ejemplo de la dirección pesa más que cualquier curso: si el jefe pide saltarse el procedimiento, el procedimiento no existe.
- La seguridad forma parte de la acogida de cada persona nueva.
- Los procedimientos seguros deben ser también los más cómodos; si no, la gente buscará atajos.

3.2. Cultura que no castiga

Quien avisa de que ha hecho clic en un enlace malicioso está dando a la organización los minutos que necesita para contener el daño. Si la respuesta es una bronca, la próxima vez callará. La regla es sencilla: se agradece el aviso y se corrige el proceso, no a la persona.

4. Ataques dirigidos a personas

Técnica	En qué consiste
Phishing	Correo masivo que suplanta a una entidad para robar credenciales o instalar malware
Spear phishing	Phishing preparado a medida para una persona o empresa concreta
Smishing	Lo mismo, por SMS o mensajería
Vishing	Suplantación por llamada telefónica
QRishing	Código QR que lleva a una web fraudulenta
Fraude del CEO (BEC)	Alguien se hace pasar por un directivo o proveedor para ordenar un pago
Pretexting	Historia inventada para ganarse la confianza y obtener información
Baiting	Cebo físico o digital: un USB «olvidado», una descarga gratuita

Dos tendencias a tener presentes: los mensajes fraudulentos ya no tienen faltas de ortografía, porque se redactan con inteligencia artificial, y la clonación de voz hace creíbles llamadas de un supuesto directivo. Las señales clásicas siguen sirviendo, pero la defensa fiable es el procedimiento: verificar por otro canal.

4.1. Las palancas que usan

Urgencia, autoridad, miedo, curiosidad, deseo de ayudar y recompensa. Cuando un mensaje aprieta una de ellas y además pide una acción inmediata, es momento de parar.

4.2. Malware y ransomware como consecuencia

El phishing rara vez es el final: es la puerta por la que entran el robo de credenciales, el malware y, a menudo, el ransomware. Se estudian en el tema 3.

5. Teletrabajo y movilidad

- Equipos corporativos gestionados, cifrados y actualizados; evitar el uso personal y familiar.
- Conexión por VPN o acceso de confianza cero, siempre con MFA.
- Wifi doméstica con contraseña robusta y router actualizado; nunca redes públicas sin protección.
- Cuidado con las pantallas y las conversaciones en lugares públicos.
- Procedimiento claro para la pérdida o robo de un dispositivo.

6. Mitigar el error humano

6.1. Comprender antes que prohibir

La gente cumple mejor lo que entiende. Explicar el porqué de una norma con un caso real funciona mejor que una lista de prohibiciones.

6.2. Hacer fácil lo correcto

- Un botón de «reportar phishing» en el cliente de correo.
- Un único punto de contacto para avisar de incidentes, conocido por todos.
- Controles técnicos que no dependan de que nadie se acuerde: MFA, filtrado de correo, bloqueo automático de pantalla.

6.3. Dar capacidad de decisión

Cualquier empleado debe sentirse autorizado a decir «esto lo compruebo antes de hacerlo», aunque quien lo pida sea, en apariencia, la dirección.

7. Protocolos por departamento

7.1. Atención al cliente y recepción

- No facilitar datos personales ni internos sin verificar la identidad del interlocutor.
- Ante una petición inusual: tomar los datos, colgar y devolver la llamada al número que consta en los sistemas.

7.2. Administración y pagos

- Ningún cambio de cuenta bancaria de un proveedor se tramita solo con un correo: se confirma por teléfono, al número ya registrado.
- Doble aprobación para pagos por encima de un importe.

- Desconfiar de la urgencia y del «no lo comentas con nadie».

7.3. Recursos humanos

- Los currículos y adjuntos de candidatos se abren en un entorno controlado.
- Los datos de nóminas y de empleados solo se envían por canales seguros y a destinatarios verificados.
- Coordinación con sistemas en altas y, sobre todo, en bajas de personal.

7.4. Dirección

Son el objetivo más rentable para un atacante y, a menudo, quienes más excepciones piden. Necesitan formación específica y las mismas normas que el resto.

8. Medir si funciona

Indicador	Qué mide
Tasa de clic en simulaciones	Cuántos caen
Tasa de reporte	Cuántos avisan: es el indicador que más importa
Tiempo hasta el primer aviso	Cuánto tarda la organización en enterarse
Incidentes reales con origen humano	El resultado final
Participación en la formación	Alcance del plan

Las simulaciones de phishing son una herramienta de aprendizaje, no una trampa: se avisa de que existen, no se señala a nadie y quien cae recibe una explicación breve en el momento.

Para ampliar

- INCIBE: kit de concienciación para empresas (gratuito, con materiales y simulaciones).
- CCN-CERT: informes de buenas prácticas (serie BP) sobre correo electrónico y dispositivos móviles.
- ENISA: guías de concienciación en ciberseguridad.
- Línea de ayuda en ciberseguridad de INCIBE: 017.